

TSEC Risk & Cyber Advisory LLC

Integrated Cybersecurity, Risk & Compliance Advisory

TSEC-FREE-001

SOC 2 Readiness Checklist

Pre-Assessment Readiness Tool for SOC 2 Type I & Type II

AICPA Trust Services Criteria (TSC) 2017

Document ID:	TSEC-FREE-001
Version:	1.0
Date:	June 2026
Classification:	CONFIDENTIAL
Prepared by:	TSEC Risk & Cyber Advisory LLC

www.tsecgrc.com | info@tsecgrc.com

1. Purpose & Instructions

This checklist is designed to help organizations assess their readiness for a SOC 2 examination. It covers the five Trust Services Criteria (TSC): Security (CC), Availability (A), Processing Integrity (PI), Confidentiality (C), and Privacy (P).

Instructions: Review each item and mark the Status column with: ✓ (Implemented), X (Not Implemented), or NA (Not Applicable). Items marked X represent gaps that must be remediated prior to the audit.

2. Security (Common Criteria — CC)

CC1–CC2: Control Environment & Communication

#	Control / Requirement	Status (✓/X/NA)
---	-----------------------	-----------------

1	A formal Information Security Policy exists and has been approved by management.	
2	Security roles and responsibilities are defined and communicated to all personnel.	
3	Background checks are performed for all employees with access to sensitive systems.	
4	Annual security awareness training is conducted and documented.	
5	Code of conduct and acceptable use policies are in place and signed by staff.	

CC3–CC4: Risk Assessment & Monitoring

#	Control / Requirement	Status (✓/✗/NA)
1	A formal risk assessment process is documented and performed at least annually.	
2	Risk treatment decisions are documented and tracked to remediation.	
3	A continuous monitoring program is in place for critical systems.	
4	Security metrics and KPIs are reported to management periodically.	

CC5–CC6: Control Activities & Logical Access

#	Control / Requirement	Status (✓/✗/NA)
1	Access provisioning follows a documented Joiner-Mover-Leaver (JML) process.	
2	Privileged access (admin/root) is restricted, documented, and reviewed quarterly.	
3	Multi-factor authentication (MFA) is enforced for all remote access and cloud systems.	
4	Password policies enforce complexity, length, and rotation requirements.	
5	Access reviews are conducted at least semi-annually for all critical systems.	
6	Terminated employee access is revoked within 24 hours of separation.	

CC7–CC9: System Operations, Change & Risk Mitigation

#	Control / Requirement	Status (✓/✗/NA)
1	A vulnerability management program scans systems at least monthly.	
2	Critical patches are applied within defined SLAs (e.g., critical within 30 days).	
3	A formal change management process controls all production changes.	
4	Change requests are tested in a non-production environment prior to deployment.	
5	An incident response plan (IRP) is documented, tested, and up to date.	

6	Security incidents are logged, investigated, and tracked to closure.	
7	Vendor and third-party risk assessments are conducted prior to onboarding.	

3. Availability (A) Criteria

Availability Controls		
#	Control / Requirement	Status (✓/X/NA)
1	System uptime and availability targets (SLAs) are defined and monitored.	
2	Business continuity and disaster recovery plans are documented and tested.	
3	Recovery Time Objective (RTO) and Recovery Point Objective (RPO) are defined.	
4	Redundant infrastructure (failover, load balancing) is in place for critical systems.	
5	Backup procedures are documented, automated, and tested at least quarterly.	

4. Confidentiality (C) Criteria

Confidentiality Controls		
#	Control / Requirement	Status (✓/X/NA)
1	A data classification policy defines categories (Public, Internal, Confidential, Restricted).	
2	Confidential data is encrypted at rest and in transit using approved algorithms.	
3	Data handling requirements are communicated to all staff and vendors.	
4	NDAs / confidentiality agreements are signed by employees and contractors.	
5	Confidential data disposal procedures are documented and enforced.	

5. Remediation Summary

Use this section to track identified gaps. For each item marked X, document the gap owner, target remediation date, and status.

Gap / Control Ref	Remediation Action	Owner	Target Date